LISTA DE VERIFICACIÓN

Seguridad en la nube: lo esencial

Recorre esta lista antes de publicar un proyecto y repítela cada trimestre. Marca cada casilla solo si puedes demostrarlo.

☐ Hecho y verificado ALTA Hazlo antes de salir a producción MEDIA Planéalo en las próximas semanas

1 IAM con mínimo privilegio

Cada persona y servicio tiene solo los permisos que necesita, y nada más.

- ☐ **Nadie usa la cuenta raíz o de propietario para el trabajo diario.** — ALTA
  Protégela con MFA y guarda sus credenciales fuera de línea.
- ☐ **MFA obligatorio para todas las personas con acceso a la consola.** — ALTA
  Prefiere llaves de seguridad o apps de autenticación sobre SMS.
- ☐ **Los permisos se asignan a grupos o roles, no a usuarios individuales.** — MEDIA
  Así, al cambiar de equipo, basta con mover a la persona de grupo.
- ☐ **Cada aplicación usa su propia cuenta de servicio con roles predefinidos acotados.** — ALTA
  Evita roles amplios como «Editor» u «Owner» en cuentas de servicio.
- ☐ **Se revisan los accesos cada trimestre y se quitan los que no se usan.** — MEDIA
  Usa el recomendador de IAM o los informes de último acceso.

2 Secretos

Contraseñas, tokens y llaves nunca viajan en el código ni en la imagen.

- ☐ **Ningún secreto está en el repositorio, ni siquiera en el historial de Git.** — ALTA
  Activa un escáner de secretos en el CI y en los pull requests.
- ☐ **Los secretos viven en un gestor (Secret Manager, Vault o similar).** — ALTA
  La app los lee al arrancar con su cuenta de servicio.
- ☐ **Las llaves y contraseñas se rotan con una frecuencia definida.** — MEDIA
  Por ejemplo, cada 90 días, o de inmediato si alguien sale del equipo.
- ☐ **No se crean llaves JSON de cuentas de servicio si hay alternativa.** — MEDIA
  Usa identidades administradas o federación de identidades.

3 Redes privadas

Solo lo que debe ser público tiene una IP pública.

- ☐ **Las VMs y bases de datos no tienen IP pública.** — ALTA
  El tráfico entra por un balanceador y sale por Cloud NAT.
- ☐ **El firewall deniega toda la entrada por defecto y abre solo puertos concretos.** — ALTA
  Ninguna regla con 0.0.0.0/0 hacia SSH (22) o RDP (3389).
- ☐ **El acceso administrativo pasa por un bastión o un proxy con identidad.** — ALTA
  Por ejemplo, IAP o una VPN, nunca SSH abierto a internet.
- ☐ **Los entornos (desarrollo, pruebas, producción) están en redes separadas.** — MEDIA
  Un error en desarrollo no debe alcanzar datos de producción.

4 HTTPS en todas partes

Todo el tráfico va cifrado, también el interno cuando sea posible.

- [ ] **Todas las URL públicas usan HTTPS con certificados administrados.** — ALTA
  Los certificados se renuevan solos; revisa que no haya vencidos.
- [ ] **HTTP redirige a HTTPS y se envía la cabecera HSTS.** — MEDIA
  Strict-Transport-Security: max-age=31536000
- [ ] **Solo se aceptan TLS 1.2 o superior.** — MEDIA
  Configura una política SSL moderna en el balanceador.
- [ ] **Las conexiones a la base de datos usan TLS.** — MEDIA
  Exige SSL en el servidor y verifica el certificado en el cliente.

5 Copias de seguridad

Una copia que nunca se ha restaurado es solo una esperanza.

- [ ] **Las bases de datos tienen copias automáticas diarias y recuperación a un punto en el tiempo.** — ALTA
  Define cuántos datos puedes perder (RPO) y en cuánto tiempo debes volver (RTO).
- [ ] **Al menos una copia está en otra región y fuera del alcance de las cuentas de producción.** — ALTA
  Así un borrado accidental o un ransomware no se lleva todo.
- [ ] **Los buckets críticos tienen versionado o bloqueo de retención.** — MEDIA
  Permite recuperar archivos sobrescritos o eliminados.
- [ ] **Se prueba una restauración completa al menos cada trimestre.** — ALTA
  Anota cuánto tardó y actualiza el procedimiento.

6 Registro y monitoreo

Si no queda registro, no puedes saber qué pasó.

- [ ] **Los registros de auditoría (quién hizo qué y cuándo) están activos.** — ALTA
  Incluye los registros de acceso a datos en los servicios sensibles.
- [ ] **Los logs se guardan en un destino central con retención definida.** — MEDIA
  Por ejemplo, 400 días para auditoría; restringe quién puede borrarlos.
- [ ] **Hay alertas para eventos críticos.** — ALTA
  Cambios de IAM, reglas de firewall abiertas, muchos errores 5xx o inicios de sesión fallidos.
- [ ] **Las alertas llegan a una persona de guardia, no a un correo que nadie lee.** — MEDIA
  Prueba el canal de alertas al menos una vez al mes.

Resultado: ___ de 25 casillas marcadas. Cualquier punto de prioridad **Alta** sin marcar es un pendiente bloqueante.

Proyecto	Revisado por	Fecha